Professional Issues in IT

DATA PROTECTION AND PRIVACY

Data Protection

Background :

- Public concern about data protection was first aroused when it was realized that a very large amount of data about individuals was being collected and stored in computers and then used for purposes that were not only different from those intended when the data was collected, but also unacceptable.
- There were also concerns that unauthorized people could access such data and that the data might be out of date, incomplete or just plain wrong.

Data Protection

- The General Data Protection Regulation (GDPR) became law across all member countries of the European Union (EU).
- From one perspective, the GDPR is an evolution of data protection laws that have been developed in Europe since the 1970s. The GDPR updates these laws to reflect modern concerns about how organisations collect, track and use data about citizens and residents in the EU.

Data Protection Act 1984

These concerns surfaced in the 1970s.

They were particularly strong in the UK and the rest of Europe and led to a Council of Europe Convention on the subject.

The first UK Data Protection Act, passed in 1984, was designed to implement the provisions of the Convention.

It was designed to protect individuals from:

- the use of inaccurate personal information or information that is incomplete or irrelevant;
- the use of personal information by unauthorized persons;
- the use of personal information for purposes other than that for which it was collected.

Progressing of the Act

By the mid-1990s, a different danger had become apparent.

- As individuals began to use the internet for an ever wider range of purposes, it became possible to capture information about the way individuals use the internet and to build profiles of their habits that can be used for marketing purposes and also, perhaps, for more sinister purposes such as blackmail.
- What is more, this can be done by much smaller and much shadowier organizations than those that were the object of the 1984 Act.
- These and other concerns led in 1995 to the European Directive on Data Protection which, in turn, led to the 1998 Data Protection Act.

DATA PROTECTION

The first UK legislation on data protection was the 1984 Data Protection Act. However, this was taken over by the 1998 Act.

- The Act defines a number of terms that are widely used in discussions of data protection issues. In some cases these are different from the terms used in the 1984 Act.

To get a clear picture we need to be familiar with some terminologies regarding Data protection

There are some classes of data that are not covered by the UK GDPR.

- The first class is data used for domestic or household purposes (including
- recreation).
- The other two classes concern law enforcement and intelligence services; however, the DPA 2018 does have provisions regarding these two classes.
- In addition, there is the so-called special purposes exemption, which protects processing for the purposes of journalism, art and literature, and academic work in appropriate circumstances.

Terminology

Data is a set of facts, and information is the result of processing the data and interpreting it.

Data controller means a person who determines why or how personal data is processed. This may be a legal person or a natural person.

- *Data processor*, in this context, means anyone who processes personal data on behalf of the data controller and who is not an employee of the data controller. This might include an application service provider, such as a company that provides online hotel booking services.

Processing means any action that is performed on the data, which the DPA 2018 states as encompassing 'obtaining, recording, holding, using, disclosing and erasing data'.

Terminology ……

- *Data subject* means the individual who is the subject of personal data.
- *Sensitive personal data* means personal data relating to the racial or ethnic origin of data subjects, their political opinions, their religious beliefs, whether they are members of trade unions, their physical or mental health, or whether they have committed or are alleged to have committed any criminal offence. The rules regarding the processing of sensitive personal data are stricter than for other personal data.

Processing

- *Processing* means obtaining, recording or holding the information or data

or carrying out any operations on it, **including:**

(a) organization, adaptation or alteration of the information or data,

(b) retrieval, consultation or use of the information or data,

(c) disclosure of the information or data by transmission, dissemination or otherwise making available, or

(d) alignment, combination, blocking, erasure or destruction of the information or data.

Data protection principles

The 1998 Act lays down eight data protection principles, which apply to the collection and processing of personal data of any sort.

Data controllers are responsible for ensuring that these principles are complied with in respect of all the personal data for which they are responsible.

First data protection principle

- **“Personal data shall be processed fairly and lawfully and in particular shall not be processed unless (a) at least one of the conditions in Schedule 2 is met and(b) in the case of sensitive personal data, at least one of the conditions in Schedule 3 is also met.”**

- The most significant condition in Schedule 2 of the Act is that the data subject has given their consent. If this is not the case, then the data can only be processed if the data controller is under a legal or statutory obligation for which the processing is necessary.
- For processing sensitive personal information, Schedule 3 requires that the data subject has given explicit consent.

Second data protection principle

- **“Personal data shall be obtained only for one or more specified and lawful purposes, and shall not be further processed in any manner incompatible with that purpose or those purposes.”**

- Data controllers must notify the Information Commissioner of the personal data they are collecting and the purposes for which it is being collected.

Third data protection principle

- **“Personal data shall be adequate, relevant and not excessive in relation to the purpose or purposes for which they are processed.”**

- Data controllers need procedures to assess planned data collection, checking what is requested and whether there is an adequate justification for each item of data.

Fourth data protection principle

"Personal data shall be accurate and, where necessary, kept up to date."

- While this principle is admirable, it can be extremely difficult comply with.

Examples: In the UK, doctors have great difficulty in maintaining up-to-date data about their patients' addresses, particularly patients who are students, because students change their addresses frequently and rarely remember to tell their doctor.

Universities have similar difficulties.

Fifth data protection principle

"Personal data processed for any purpose or purposes shall not be kept for longer than is necessary for that purpose or those purposes."

This principle raises more difficulties than might be expected:

- It is necessary to establish how long each item of personal data needs to be kept. Auditors will require that financial data is kept for seven years. Action in the civil courts can be initiated up to six years after the events complained of took place so that it may be prudent to hold data for this length of time. It is appropriate to keep some personal data indefinitely (e.g. university records of graduating students). In all cases, the purpose for which the data is kept must be included in the purposes for which it was collected.
- Procedures to ensure that all data is erased at the appropriate time are needed, and this must include erasure from backup copies.

Sixth data protection principle

“Personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures.6

Seventh data protection principle

“Personal data shall be processed in accordance with the rights of data subjects’. Although the UK GDPR does not include this as a principle, it does specify the rights of data subjects in more detail.”

Eighth data protection principle

“Personal data shall not be transferred to a country or territory outside the European Economic Area unless that country or territory ensures an adequate level of protection for the rights and freedoms of data subjects in relation to the processing of personal data.”

This principle can be viewed in two ways.

- It can be seen as protecting data subjects from having their personal data transferred to countries where there are no limitations on how it might be used.
- It can also be seen as specifically allowing businesses to transmit personal data across national borders provided there is adequate legislation in the destination country.

Rights of Data Subjects

The 1998 Act extends this right of access so that data subjects have the right to receive:

- right to be informed;
  - Privacy policy explaining how a fitness app processes users' data.
- right of access;
  - Requesting a copy of medical records from a hospital.
- right to rectification;
  - Correcting a misspelled name in a utility account.
- right to erasure, also known as the right to be forgotten;
  - Deleting an old social media account that is no longer in use.
- right to restrict processing;
  - Stopping data processing for a disputed insurance claim until the issue is resolved.
- right to data portability;
  - Exporting contact lists from one email service to another.

Rights of Data Subjects

The 1998 Act extends this right of access so that data subjects have the right to receive:.

- right to object;
  - Opting out of receiving marketing emails from an online retailer.
- right regarding automated decision making and profiling
  - Contesting a credit score decision made entirely by an algorithm.

Data subject rights

The 1998 Act also gives data subjects the right:

- to prevent processing likely to cause damage and distress;
- to prevent processing for the purposes of direct marketing;
- to compensation in the case of damage caused by processing of personal data in violation of the principles of the Act.

Scope of the Act

- There are a number of important exceptions or limitations to the right of subject access, for example: where disclosing the information may result in infringing someone else's rights; where the data consists of a reference given by the data controller; examination candidates do not have the right of access to their marks until after the results of the examinations have been published;
- personal data consisting of information recorded by candidates during an academic, professional or other examination are exempt from the right of access.

PRIVACY

- The starting point is the Regulation of Investigatory Powers Act 2000, which sets up a framework for controlling the lawful interception of computer, telephone and postal communications.
- The Act allows government security services and law enforcement authorities to intercept, monitor and investigate electronic data only in certain specified situations such as when preventing and detecting crime. Powers include being able to demand the disclosure of data encryption keys.

PRIVACY

Under the Act and the associated regulations, organizations that provide computer and telephone services (this includes not only ISPs (internet service providers) and other telecommunications service providers but also most employers) can monitor and record communications without the consent of the users of the service, provided this is done for one of the following purposes:

- to establish facts, for example, on what date a specific order was placed;
- to ensure that the organization's regulations and procedures are being complied with;
- to ascertain or demonstrate standards which are or ought be to be achieved;
- to prevent or detect crime (whether computer-related or not);
- to investigate or detect unauthorized use of telecommunication systems;
- to ensure the effective operation of the system, for example, by detecting viruses or denial of service attacks;

PRIVACY

- to find out whether a communication is a business communication or a private one (e.g. monitoring the emails of employees who are on holiday, in order to deal with any that relate to the business);
- to monitor (but not record) calls to confidential, counselling helplines run free of charge by the business, provided that users are able to remain anonymous if they so choose.

FREEDOM OF INFORMATION

- The primary purpose of the Freedom of Information Act is to provide clear rights of access to information held by bodies in the public sector. Under the terms of the Act, any member of the public can apply for access to such information.
- The Act also provides an enforcement mechanism if the information is not made available. The legislation applies to Parliament, government departments, local authorities, health trusts, doctors' surgeries, universities, schools and many other organizations. The main features of the Act are:

FREEDOM OF INFORMATION

- There is a general right of access to information held by public authorities in the course of carrying out their public functions, subject to certain conditions and exemptions.
- In most cases where information is exempted from disclosure, there is a duty on public authorities to disclose where, in the view of the public authority, the public interest in disclosure outweighs the public interest in maintaining the exemption in question.
- There is a new office of the Information Commissioner (see the 'Further reading' section for the website) and a new Information Tribunal, with wide powers to enforce the rights, was created.
- A duty was imposed on public authorities to adopt a scheme for the publication of information. The schemes, which must be approved by the Information Commissioner, specify the classes of information the authority intends to publish, the manner of publication and whether the information is available to the public free of charge or on payment of a fee